McGill
School of Continuing Studies | École d'éducation permanente

CCCS 454 – Security Incident Response and Recovery

Project - Part 2 – Executing a tabletop scenario

Al Labade, Ayman

Section 1: Role Execution

1. President / CEO

As the President of Apex AutoSystems, my immediate priority is the survival of the company and the safety of the public. I am activating the Crisis Management Team (CMT) immediately.

- **Strategic Decision**: I am authorizing the engagement of a third-party negotiation firm to open a channel with the attackers, solely to buy time. I am not authorizing payment yet, but I need to know if their threats are technically feasible.
- **Client Management:** I will personally call the C-level executives of our top 3 clients (Ford, GM, Toyota) to inform them of a critical system outage impacting production. I will not mention the safety threat regarding the keys until we have verified the attackers truly possess them, to avoid premature panic.
- **Financials:** I am instructing the CFO to assess our liquidity in case a ransom payment becomes the only option to save lives, while acknowledging this would violate US Treasury sanctions guidance.

2. IT Manage / CIO

My team is in full containment mode.

- **Containment:** I have ordered the immediate "severing" of the connection between our Corporate IT network and the OT Manufacturing network to ensure the ransomware doesn't spread to the robotic controllers themselves.
- **FOTA Security:** This is the critical path. I have instructed the DevSecOps team to immediately revoke the compromised signing certificate at the root CA level. This will "brick" the ability to send any updates (good or bad) to cars, effectively freezing the FOTA system. This neutralizes the attacker's threat to push malware but also means we cannot patch anything.
- **Restoration**: We are attempting to restore the MES database from cold backups (tape) stored offsite. We assume all online backups are compromised.

3. Operations Manager

The situation on the factory floor is chaotic.

- **Production Halt:** With the MES down, the robots have no instructions. I declared a "Line stop" for all facilities in Mexico and Michigan.
- **Personnel:** I am sending non-essential shift workers home with pay for the day to prevent rumors from spreading physically. I am keeping key maintenance engineers on-site to inspect the PLCs for any physical tampering.
- **Client Logistics:** I am invoking the "Force Majeure" clause in our supple contracts to mitigate the $50K/minute penalties, citing a "criminal cyber event". I am coordinating with logistics to see if any completed inventory in the warehouse can be manually shipped to clients to keep their lines running for another few hours.

4. Legal/HR

- **Liability Analysis:** My focus is on the catastrophic liability of the stolen keys. If a car crashes because of this, Apex is finished. I am preparing a legal brief on the necessity of notifying the NHTSA (National Highway Traffic Safety Administration). Federal law requires us to report safety defects within 5 days; a compromised key is a safety defect.
- **Law Enforcement:** I am contacting the FBI Cyber Division to report the extortion.
- **HR:** I am drafting an internal memo to employees advising them of a "technical outage" and reminding them of their Non-Disclosure Agreements (NDAs). Anyone leaking details to the press will face termination. We need to control the narrative.

5. Communications Director

- **External Narrative:** I have drafted a "Holding Statement" for the press: "*Apex AutoSystems is currently experiencing a technical disruption affecting our internal IT systems. Manufacturing has been temporarily paused as a precautionary measure. We are working on resolving the issue."* I am strictly avoiding the word "Ransomware" or "Safety Threat" until the CEO gives the green light.

- **Monitoring:** My team is monitoring the Dark Web forums and Twitter for any leaks from the attackers. If they publish proof of the keys, we need a "Crisis Response" ready to go that emphasizes we have already revoked the keys (per the IT Manager's action) and the public is safe, even if its not 100% true yet.

Section 2: Discussion Questions

1) To Pay or Not to Pay? (Safety vs Policy)

The decision to pay the ransom in this scenario is uniquely complex because it bridges the gap between financial loss and physical safety. Typically, the FBI and cybersecurity experts advise against paying ransoms because it funds criminal activity and offers no guarantee of data recovery. For the manufacturing database (the financial threat), Apex should absolutely not pay. We have cold backups, and while the downtime is expensive, it is a recoverable business cost.

However, the threat of using the signing keys to crash vehicles introduces an ethical dilemma. If the IT Manager cannot guarantee that revoking the keys will propagate to all vehicles immediately (e.g., if cars are offline/in tunnels), a "window of vulnerability" exists. If paying the ransom buys us the certainty that the attackers won't press the button during that window, strictly Utilitarian ethics might argue for payment to save lives.

2) Disclosure and Panic

The question of when to disclose the breach of the signing of keys is a matter of "Responsible Disclosure" versus "Public Safety."

- Immediate Disclosure: Announcing "Our keys are stolen, your car might be hacked" immediately would cause mass panic. People might stop driving, causing economic gridlock. It might also provoke the attackers to act faster before the keys are revoked.
- Delayed Disclosure: Keeping it secret allows the engineers time to revoke the certificates and push a "killer patch" that rejects the old keys. This is the standard industry approach.

Decision: Apex should adopt a middle ground. We must immediately disclose to the Regulatory Bodies (NHTSA) and the OEM Clients (Ford, GM) under strict confidentiality. This allows the OEMs to prepare their own safety nets. We should not issue a general press release to the public until the "Key Revocation" signal has been confirmed and received by 90% of the active fleet. Public disclosure before mitigation offers no benefit to the driver (they can't fix it themselves) and only invites chaos.